四、安全规约

1. 【强制】隶属于用户个人的页面或者功能必须进行权限控制校验。
   说明：防止没有做水平权限校验就可随意访问、修改、删除别人的数据，比如查看他人的私信内容。

2. 【强制】用户敏感数据禁止直接展示，必须对展示数据进行脱敏。
   正例：中国大陆个人手机号码显示：139****1219，隐藏中间 4 位，防止隐私泄露。

3. 【强制】用户输入的 SQL 参数严格使用参数绑定或者 METADATA 字段值限定，防止 SQL 注入，禁止字符串拼接 SQL 访问数据库。
   反例：某系统签名大量被恶意修改，即是因为对于危险字符#--没有进行转义，导致数据库更新时，where 后边的信息被注释掉，对全库进行更新。

4. 【强制】用户请求传入的任何参数必须做有效性验证。
   说明：忽略参数校验可能导致：
   - 页面 page size 过大导致内存溢出
   - 恶意 order by 导致数据库慢查询
   - 缓存击穿
   - SSRF
   - 任意重定向
   - SQL 注入，Shell 注入，反序列化注入
   - 正则输入源串拒绝服务 ReDoS
     扩展：Java 代码用正则来验证客户端的输入，有些正则写法验证普通用户输入没有问题，但是如果攻击人员使用的是特殊构造的字符串来验证，有可能导致死循环的结果。

5. 【强制】禁止向 HTML 页面输出未经安全过滤或未正确转义的用户数据。
   说明：XSS 跨站脚本攻击。它指的是恶意攻击者往 Web 页面里插入恶意 html 代码，当用户浏览时，嵌入其中 Web 里面的 html 代码会被执行，造成获取用户 cookie、钓鱼、获取用户页面数据、蠕虫、挂马等危害。

6. 【强制】表单、AJAX 提交必须执行 CSRF 安全验证。
   说明：CSRF (Cross-site request forgery) 跨站请求伪造是一类常见编程漏洞。对于存在 CSRF 漏洞的应用/网站，攻击者可以事先构造好 URL，只要受害者用户一访问，后台便在用户不知情的情况下对数据库中用户参数进行相应修改。

7. 【强制】URL 外部重定向传入的目标地址必须执行白名单过滤。
   说明：攻击者通过恶意构造跳转的链接，可以向受害者发起钓鱼攻击。

8. 【强制】在使用平台资源，譬如短信、邮件、电话、下单、支付，必须实现正确的防重放的机制，如数量限制、疲劳度控制、验证码校验，避免被滥刷而导致资损。
   说明：如注册时发送验证码到手机，如果没有限制次数和频率，那么可以利用此功能骚扰到其它用户，并造成短信平台资源浪费。

9. 【强制】对于文件上传功能，需要对于文件大小、类型进行严格检查和控制。
   说明：攻击者可以利用上传漏洞，上传恶意文件到服务器，并且远程执行，达到控制网站服务器的目的。

10. 【强制】配置文件中的密码需要加密。

11. 【推荐】发贴、评论、发送等即时消息，需要用户输入内容的场景。必须实现防刷、内容违禁词过滤等风控策略。